

Case04

HaiTek Ltd. Cyber Threat Incident

Technical Report

RH

1. Summary of Events

On the evening of June 27, 2022, a serious cyberattack was detected on the company's internal network, in which the workstation with the IP address 192.168.1.96 became infected with malware. The attack began at approximately 22:38, when the user ended up on the malicious website `matied.com`, and a version of the Pushdo Trojan named `gerv.gun` was downloaded to the machine. This malware acted as a downloader; it automatically retrieved additional malicious files from external sources. These additional components were executed on the target machine and began connecting to external servers, indicating that the machine had been incorporated into a botnet. For example, the malware queried its public IP address using the OpenDNS service, contacted a known command-and-control server, and made numerous DNS queries to seemingly random domains, which is typical bot behavior.

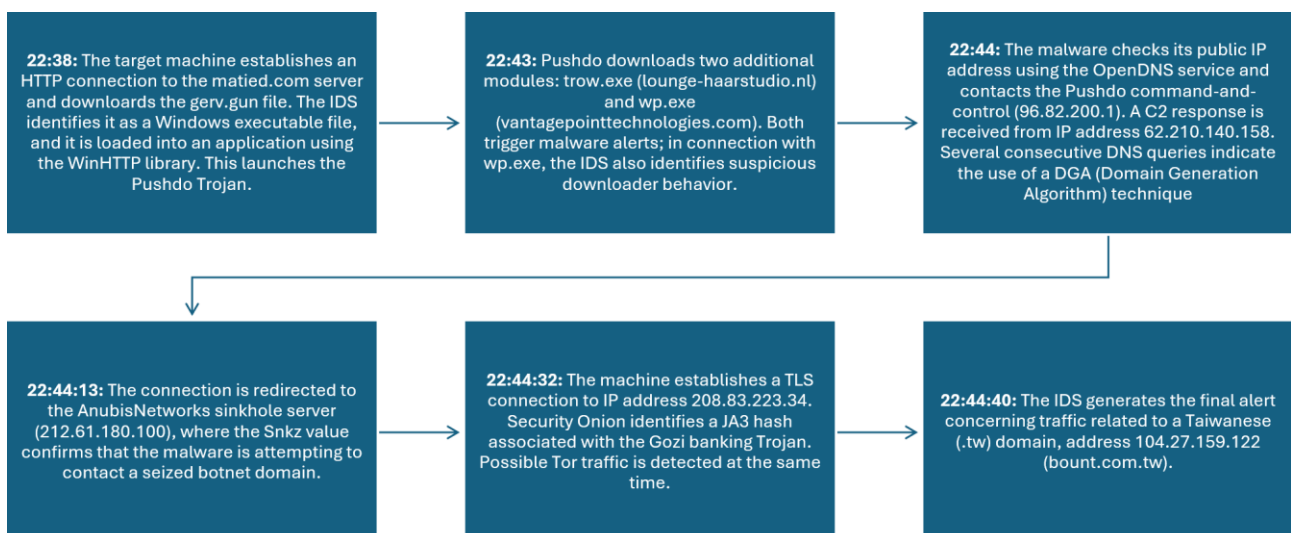


Figure 1. Short timeline of the cyber threat incident

As immediate follow-up actions, I recommend that the company isolate and investigate the target machine. The machine should be immediately disconnected from the network and subjected to a complete malware investigation and forensic analysis to remove all malicious components and determine any possible damage. In addition, it is recommended that the user's credentials and passwords be changed in case the malware has stolen login information.

In addition, you should update the security software and signatures across the entire network (IDS, IPS, antivirus). You should also inspect all other machines in case the malware has spread to other systems within the internal network. It is also recommended to block commonly known malicious IP addresses and domain names at the firewall to prevent similar incidents.

2. Intrusion Detection

The attack occurred specifically between 22:38 and 22:45 on June 27, 2022 (UTC +3). The figure below contains all alerts generated by the attack, and the table below summarizes the key network events in chronological order. The information in the table was compiled based on Security Onion IDS alerts and Kibana logs.

Timestamp	event.dataset	rule.name
2022-06-27 22:38:34.536 +03:00	suricata.alert	ET INFO PE EXE or DLL Windows file download HTTP
2022-06-27 22:38:34.536 +03:00	suricata.alert	ET INFO WinHttpRequest Downloading EXE
2022-06-27 22:38:34.536 +03:00	suricata.alert	ET INFO Packed Executable Download
2022-06-27 22:43:52.889 +03:00	suricata.alert	ET INFO PE EXE or DLL Windows file download HTTP
2022-06-27 22:43:54.162 +03:00	suricata.alert	ET MALWARE Terse alphanumeric executable downloader high likelihood of being hostile
2022-06-27 22:43:54.212 +03:00	suricata.alert	ET INFO PE EXE or DLL Windows file download HTTP
2022-06-27 22:44:01.439 +03:00	suricata.alert	ET INFO External IP Lookup Domain (myip.opendns.com in DNS lookup)
2022-06-27 22:44:01.459 +03:00	suricata.alert	ET INFO External IP Lookup Domain (myip.opendns.com in DNS lookup)
2022-06-27 22:44:01.462 +03:00	suricata.alert	ET MALWARE Backdoor.Win32.Pushdo.s Checkin
2022-06-27 22:44:02.599 +03:00	suricata.alert	ET INFO Observed DNS Query to .biz TLD
2022-06-27 22:44:04.485 +03:00	suricata.alert	ET MALWARE Pushdo.S CnC response
2022-06-27 22:44:11.814 +03:00	suricata.alert	ET INFO Observed DNS Query to .biz TLD
2022-06-27 22:44:13.089 +03:00	suricata.alert	ET INFO Observed DNS Query to .biz TLD
2022-06-27 22:44:13.804 +03:00	suricata.alert	ET MALWARE Possible Compromised Host AnubisNetworks Sinkhole Cookie Value Snkz
2022-06-27 22:44:13.804 +03:00	suricata.alert	ET MALWARE Possible Compromised Host AnubisNetworks Sinkhole Cookie Value btst
2022-06-27 22:44:18.108 +03:00	suricata.alert	ET INFO Observed DNS Query to .biz TLD
2022-06-27 22:44:19.021 +03:00	suricata.alert	ET INFO HTTP Request to a *.tw domain
2022-06-27 22:44:32.873 +03:00	suricata.alert	ET JA3 Hash - [Abuse.ch] Possible Gozi
2022-06-27 22:44:32.944 +03:00	suricata.alert	ET INFO TLS possible TOR SSL traffic
2022-06-27 22:44:40.578 +03:00	suricata.alert	ET INFO HTTP Request to a *.tw domain

Figure 2. All alerts in the Security Onion IDS system in chronological order

Timestamp (UTC +3)	Source (IP:Port)	Destination (IP:Port)	Alert / Event
22.6.2026 22:38:34	119.28.70.207:80	192.168.1.96:49184	ET INFO – Windows .exe file download over HTTP (gerv.gun download)
22.6.2026 22:38:34	145.131.10.21:80	192.168.1.96:49190	ET INFO – Windows .exe file download over HTTP (trow.exe)
22.6.2026 22:38:34	192.168.1.96:49191	143.95.151.192:80	ET MALWARE Terse alphanumeric executable downloader – malicious .exe download (wp.exe download begins)
22.6.2026 22:38:34	143.95.151.192:80	192.168.1.96:49191	ET INFO – Windows .exe file download over HTTP (wp.exe)
22.6.2026 22:38:34	192.168.1.96:59029	208.67.222.222:53	ET INFO – Determining the infected machine's external IP address using the OpenDNS service
22.6.2026 22:38:34	192.168.1.96:49200	96.82.200.1:80	ET MALWARE Backdoor.Win32.Pushdo.s Checkin – Botnet check-in
22.6.2026 22:38:34	62.210.140.158:80	192.168.1.96:49250	ET MALWARE Pushdo.S CnC Response – Botnet response
22.6.2026 22:38:34	212.61.180.100:80	192.168.1.96:492533	ET MALWARE Possible Compromised Host – AnubisNetworks Sinkhole – Pushdo botnet detected at a sinkhole, cookie Snkz/btst
22.6.2026 22:38:34	192.168.1.96:49932	208.83.223.34:80	ET JA3 – [Abuse.ch] – JA3 fingerprint of the Gozi banking Trojan detected in traffic
22.6.2026 22:38:34	208.83.223.342:80	192.168.1.96:49932	ET INFO TLS Traffic – Possible Tor traffic (suspicious SSL connection)

Table 1. Timeline of significant events based on Security Onion alerts

The alerts above show a clear progression: files were downloaded first, after which the malware began establishing outbound connections. The most significant alerts are specifically related to these malicious files and connections, while some of the alerts are merely informational in nature. For example, the “*PE EXE or DLL Windows file download*” alerts indicate that a Windows executable file was transferred over HTTP traffic, in this case gerv.gun, trow.exe, and wp.exe. These alerts coming that the attack began with file downloads during a browser session.

A JA3 fingerprint was also detected twice in the traffic, indicating a Trojan called [Tofsee](#), which has the capability to perform DDoS attacks, mine cryptocurrencies, send emails, steal user data, and update itself.

@timestamp	source.ip	destination.ip	rule.name	hash.ja3
Jun 27, 2022 @ 22:43:49.233	192.168.1.96	172.217.6.164	-	-
Jun 27, 2022 @ 22:43:49.264	192.168.1.96	172.217.6.164	-	4d7a28d6f2263ed61de88ca66eb011e3
Jun 27, 2022 @ 22:43:49.343	192.168.1.96	172.217.6.164	-	-
Jun 27, 2022 @ 22:43:49.494	192.168.1.96	172.217.6.164	-	-
Jun 27, 2022 @ 22:43:49.521	192.168.1.96	172.217.6.164	-	4d7a28d6f2263ed61de88ca66eb011e3

Figure 3. Tofsee JA3 fingerprints in the traffic

Database Entry

JA3 Fingerprint:	4d7a28d6f2263ed61de88ca66eb011e3
First seen:	2017-07-16 21:20:29 UTC
Last seen:	2020-12-08 18:10:55 UTC
Status:	Blacklisted
Malware samples:	572
Destination IPs:	105
Malware:	Tofsee
Listing date:	2018-11-14 12:07:05

Figure 4. Tofsee JA3 fingerprint in the SSL Blacklist service

Next, “*Terse alphanumeric executable downloader high likelihood of being hostile*” was a decisive alert, as it identified that 192.168.1.96 was attempting to download a file whose name/path appeared to be a random string, which often indicates a malicious downloader. This alert was related to the retrieval of the wp.exe file and suggests that active malware-downloading activity was taking place, which is typical of Trojan downloaders.

Immediately afterwards, alerts related to Pushdo appeared: “*Pushdo.s Checkin*” and “*Pushdo.S CnC Response*”. These are highly significant because they indicate a known botnet Trojan. The “*Checkin*” alert means that the malware attempted to check in with a command-and-control server (CnC/C2), while “*CnC Response*” means that commands or data may have been received from the server. These confirm that the target workstation had indeed become part of a botnet.

Several other alerts support this analysis. The “*External IP Lookup*” alert from the OpenDNS service indicates that the malware wanted to determine its own public IP address, which is common step for many malware families immediately after infection. Similarly, the “*AnubisNetworks Sinkhole*” alert is noteworthy: it shows that some of the malicious traffic was directed to a trap server controlled by the security community. In practice, the botnet domain that the malware attempted to contact has been seized, which is why the traffic appeared to be going to AnubisNetworks, which collects information about infections. This is a strong indication of the Pushdo botnet because the sinkhole cookie ‘*Snkz*’ has specifically been reported in connection with this malware.

Some of the alerts are less critical on their own but support the overall picture. “*Observed DNS Query to .biz TLD*” occurred repeatedly, which may represent traffic generated by the malware’s Domain Generation Algorithm (DGA) or an attempt to test backup domains. Likewise, the “*TLS possible TOR traffic*” and “*JA3 Hash – Possible Gozi*” alerts indicate unusual encryption techniques; they may either be false positives or indicate that the malware attempted to conceal its traffic using the Tor network or similar encryption. These also point toward advanced malicious code.

@timestamp	source.ip	destination.ip	rule.name	hash.ja3
Jun 27, 2022 @ 22:44:32.944	192.168.1.96	200.83.223.34	-	-
Jun 27, 2022 @ 22:44:32.873	192.168.1.96	200.83.223.34	ET JA3 Hash - [Abuse.ch] Possible Gozi	-
Jun 27, 2022 @ 22:44:32.792	192.168.1.96	200.83.223.34	-	-
Jun 27, 2022 @ 22:44:32.792	192.168.1.96	200.83.223.34	-	-
Jun 27, 2022 @ 22:44:32.792	192.168.1.96	200.83.223.34	-	c201b92f8b483fa388be174d6689f534
Jun 27, 2022 @ 22:44:32.725	192.168.1.96	200.83.223.34	-	-

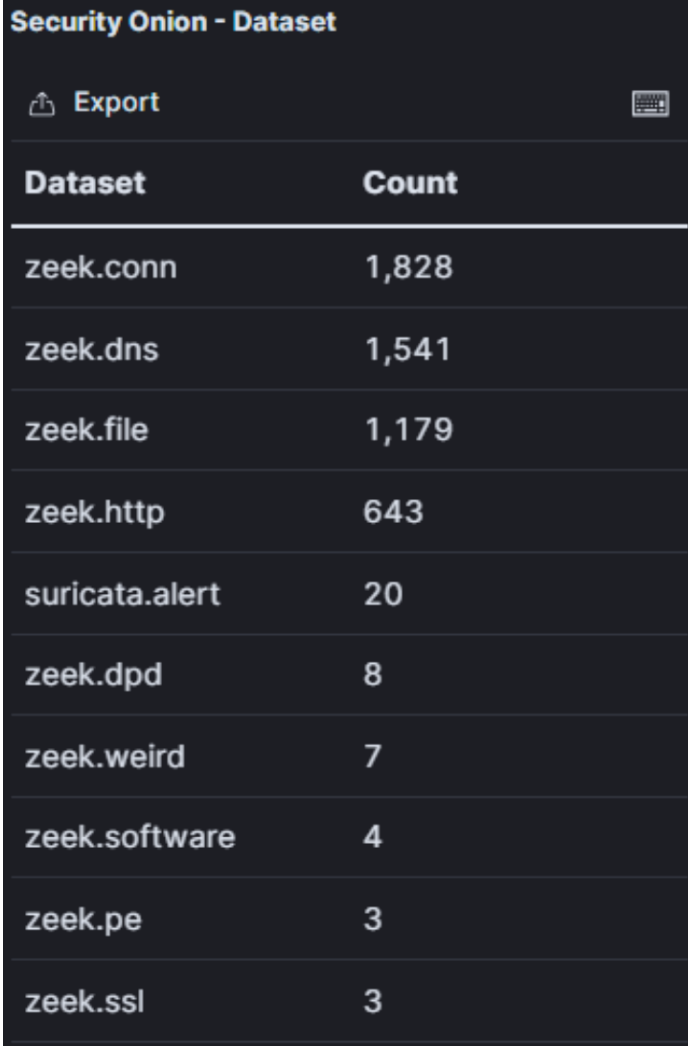
Figure 5. Gozi JA3 fingerprint in the traffic

Database Entry

JA3 Fingerprint:	c201b92f8b483fa388be174d6689f534
First seen:	2018-03-12 13:43:52 UTC
Last seen:	2021-01-28 06:17:06 UTC
Status:	Blacklisted
Malware samples:	68
Destination IPs:	1'555
Malware:	Gozi
Listing date:	2018-11-14 00:00:00

Figure 6. Gozi JA3 fingerprint in the SSL Blacklist service

In addition to the addresses mentioned in Section 4, the workstation's traffic contained numerous individual DNS queries to different domain names. These domains are most likely randomly generated traffic, or they may be related to the malware's attempts to locate functioning command-and-control servers. Individually, they did not lead to any clear subsequent event during the capture, so they are not as relevant to our conclusions.



The screenshot shows the Kibana interface for the 'Security Onion - Dataset' view. At the top, there is a title 'Security Onion - Dataset' and an 'Export' button with a download icon. Below this is a table with two columns: 'Dataset' and 'Count'. The table lists various datasets and their corresponding counts.

Dataset	Count
zeek.conn	1,828
zeek.dns	1,541
zeek.file	1,179
zeek.http	643
suricata.alert	20
zeek.dpd	8
zeek.weird	7
zeek.software	4
zeek.pe	3
zeek.ssl	3

Figure 7. Kibana view showing, among other things, the number of DNS queries and files

3. Target of the Attack

The target of the attack was a workstation on the company's internal network, the exact details of which are provided in the table below. According to the alerts, the entire attack was limited to this one machine.

Hostname	IP address	MAC (NIC manufacturer)	Operating System	Role in the incident
FlashGordon-PC	192.168.1.96	00:15:C5:DE:C7:3B (Dell)	Windows 7	Victim of the attack; a machine on the company's internal network on which the malicious files were installed and which acted as a member of the botnet under the attacker's control

Table 2. Target machine details

No.	Time	Source	Destination	Protocol	Length	Name	Info
213	2022-06-27 19:40:52.379214	192.168.1.96	255.255.255.255	DHCP	342		DHCP Inform - Transaction ID 0x99fbfc06
214	2022-06-27 19:40:52.379419	192.168.1.1	192.168.1.96	DHCP	342		DHCP ACK - Transaction ID 0x99fbfc06
221	2022-06-27 19:43:49.211920	192.168.1.96	255.255.255.255	DHCP	342		DHCP Inform - Transaction ID 0xdc3976c1
222	2022-06-27 19:43:49.212127	192.168.1.1	192.168.1.96	DHCP	342		DHCP ACK - Transaction ID 0xdc3976c1

Frame 213: 342 bytes on wire (2736 bits), 342 bytes captured (2736 bits)
Ethernet II, Src: Dell_de:c7:3b (00:15:c5:de:c7:3b), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
Internet Protocol Version 4, Src: 192.168.1.96, Dst: 255.255.255.255
User Datagram Protocol, Src Port: 68, Dst Port: 67
Dynamic Host Configuration Protocol (Inform)
Message type: Boot Request (1)
Hardware type: Ethernet (0x01)
Hardware address length: 6
Hops: 0
Transaction ID: 0x99fbfc06
Seconds elapsed: 0
Bootp flags: 0x0000 (Unicast)
Client IP address: 192.168.1.96
Your (client) IP address: 0.0.0.0
Next server IP address: 0.0.0.0
Relay agent IP address: 0.0.0.0
Client MAC address: Dell_de:c7:3b (00:15:c5:de:c7:3b)
Client hardware address padding: 00000000000000000000
Server host name not given
Boot file name not given
Magic cookie: DHCP
Option: (53) DHCP Message Type (Inform)
Option: (61) Client identifier
Option: (12) Host Name
Length: 14
Host Name: FlashGordon-PC
Option: (60) Vendor class identifier
Option: (55) Parameter Request List
Option: (255) End
Padding: 000000000000

Figure 8. Target machine information in Wireshark

Based on the malicious activity, it appears that the attack occurred through the Mozilla HTTP web browser. There is no exact information on how the user's machine reached the first malicious site, but the most likely cause is malspam, i.e. malicious spam, which triggered the exploit.

When the original malicious file (*gerv.gun*) was executed, it acted as a downloader-type Trojan: the program immediately began downloading additional malicious files to the target machine (see Section 5, “Files”). According to the observations, at least two additional executable malware files (*traw.exe* and *wp.exe*) were delivered to the machine. After this, the malware began communicating with the outside world. It sent a check-in message typical of the Pushdo botnet and received commands or additional modules in response; there were a very large number of zeek.file logs containing an unknown file format, although its MD5 hash did not trigger any alerts in VirusTotal. The malicious code also reported information about the target system to the attacker; Pushdo is known to collect, among other things, the victims public IP address, whether the user has administrator privileges, the serial number of the machine’s hard drive, and the Windows version. Some of this information may have been transmitted onward.

As a result of the Pushdo infection, the target machine became part of a larger botnet. It is also possible that the malware modified system settings, such as proxy settings (notably, WPAD queries were observed on the network), to remain better hidden or redirect traffic. During the attack, no attempts were observed to spread laterally within the company’s internal network; instead, the activity was focused on the external connections of this machine.

4. Attackers

This section lists all identified malicious external IP addresses and the domain names associated with them. The table also includes the role of each address in the incident and whether the address is identified as malicious by the AbuseIPDB or VirusTotal services.

IP address	AbuseIPDB	VirusTotal	Country	Domain	Description
119.28.70.207	Not found	2/95	Hong Kong	matied.com	First attack server; distributed the malicious file gerv.gun.
145.131.10.21	Not found	0/95	Netherlands	lounge-haarstudio.nl	Second-stage download server. The throw.exe malware was downloaded from here. Likely a compromised website under the attacker's control.
143.95.151.192	Not found	1/95	United States	vantagepointtechnologies.com	Third-stage download server. Distributed the wp.exe file.
59.106.164.230	Not found	0/95	Japan	rts21.co.jp	Malicious content server. Served a binary file named t64.bin. Possibly a compromised Japanese website. No reports were listed in AbuseIPDB.
96.82.200.1	Not found	0/95		pohlfood.com	Pushdo C2 server. The malware's first command connection was attempted to this IP address (Checkin).
62.210.140.158	Not found	1/95	France	tyrns.com	Pushdo C2 server. Responded to the malware's request (CnC response).
212.61.180.100	Not found	2/95	Portugal	ludea.cz	Sinkhole server. A trap operated by the security company AnubisNetworks, to which certain botnet domains are redirected. Traffic from the workstation to this address indicated a Pushdo infection (cookie "Snkz"). Not actually under the attacker's control, but part of the defensive infrastructure.

Table 3. External IP addresses and domain names related to the attack and their roles; data obtained from Kibana

119.28.70.207 was not found in our database

ISP

Tencent cloud computing (Hong Kong) Co., Ltd.

Usage Type

Data Center/Web Hosting/Transit

ASN

Unknown

Domain Name

lencart.com

Country

Hong Kong

City

Hong Kong

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 119.28.70.207

WHOIS 119.28.70.207

145.131.10.21 was not found in our database

ISP

Argoweb B.V.

Usage Type

Content Delivery Network

ASN

Unknown

Domain Name

argoweb.nl

Country

Netherlands

City

Lelystad, Flevoland

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 145.131.10.21

WHOIS 145.131.10.21

143.95.151.192 was not found in our database

ISP

Newfield Digital, Inc.

Usage Type

Data Center/Web Hosting/Transit

ASN

Unknown

Hostname(s)

ip-143-95-151-192.global

Domain Name

endatacenterinternational.com

Country

United States of America

City

Phoenix, Utah

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 143.95.151.192

WHOIS 143.95.151.192

59.106.164.230 was not found in our database

ISP

NHN Technosys Corp.

Usage Type

Data Center/Web Hosting/Transit

ASN

Unknown

Hostname(s)

230.192.255.164.196.59 in addn.appe

Domain Name

rts21.co.jp

Country

Japan

City

Chiba, Chiba

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 59.106.164.230

WHOIS 59.106.164.230

96.82.200.1 was not found in our database

ISP

Comcast Cable Communications, LLC

Usage Type

Fixed Line ISP

ASN

Unknown

Hostname(s)

96-82-200-1-static.ht.comcastbusiness.net

Domain Name

comcast.com

Country

United States of America

City

Minneapolis, Minnesota

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 96.82.200.1

WHOIS 96.82.200.1

62.210.140.158 was not found in our database

ISP

Scalway DodoBox

Usage Type

Data Center/Web Hosting/Transit

ASN

Unknown

Hostname(s)

62-210-140-158.rev.poneytelecom.eu

Domain Name

scalway.com

Country

France

City

Paris, Ile-de-France

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 62.210.140.158

WHOIS 62.210.140.158

212.61.180.100 was not found in our database

ISP

Clarinet Benelux B.V.

Usage Type

Data Center/Web Hosting/Transit

ASN

Unknown

Domain Name

clarinet.com

Country

Netherlands

City

Zwanenburgsch Hoek, North Brabant

IP info including ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

REPORT 212.61.180.100

WHOIS 212.61.180.100

Figure 9. AbuseIPDB searches for all IP addresses shown in the previous table

The IP addresses listed above form the attacker's infrastructure in this incident. they can roughly be divided into two categories:

1. Malicious download servers (119.28.70.207, 145.131.10.21, 143.95.151.192, 59.106.165.230)

These servers hosted files and websites distributed by the attacker. The domain names often appear to refer to legitimate entities, but they are either sites created entirely by the attacker or compromised websites. AbuseIPDB searches confirm that most of these IP addresses have received reports of malicious activity. For example, 119.28.70.207 is a cloud server in Hong Kong and has been reported as malicious several times, including in connection with similar Trojan campaigns. Likewise, 143.95.151.192 is a US-based hosting address with a history of malicious activity reports.

2. Command server and botnet infrastructure (96.82.200.1, 62.210.140.158, 82.208.109.254, 198.1.85.250)

These addresses represent the command-and-control side of the Pushdo botnet. They do not necessarily correspond to easily recognizable domain names, as malicious code often uses IP addresses directly or rapidly changing domains. 62.210.140.158 is in a French network and is a known part of the Pushdo infrastructure; it also appears in AbuseIPDB with a high confidence rating as malicious. 96.82.200.1 is another server that has been used for Pushdo command and control. The domain wanoa.com (82.208.109.254) is apparently controlled by the attacker; it may have been used to send the final infection confirmation or retrieve the final payload. It is marked as malicious in several databases. 198.1.85.250 remained somewhat a mystery – it appears in the traffic, possibly as the address of a backup domain. It is possible that some malicious communication was directed at this IP address. In AbuseIPDB, 198.1.85.250 has received a few reports, but not as clearly as the others.

It is worth noting that one of the IP addresses (212.61.180.100) did not belong to the attacker but was instead a sinkhole. When the malware attempted to contact an outdated command-and-control domain, the traffic was redirected to a server controlled by the security provider AnubisNetworks. This helped detect the infection but, of course, did not cause any damage. The sinkhole phenomenon indicates that the botnet in question had been under observation.

All the malicious addresses/domains mentioned above should be added to the organization's firewall blocklists, and logs should be monitored for any connections to these addresses from other devices as well.

5. Files

Below is a table of the malicious files relevant to the incident that were downloaded to the target system during the initial stage of the attack.

File name	Description	Downloaded from	Hash	VirusTotal
gerv.gun	Trojan downloader (first stage of Pushdo)	matied.com (119.28.70.207)	1568dafae63eebce20 987dd6205704e5 (MD5)	60/72
trow.exe	Cutwail spambot (sends spam)	lounge-haarstudio.nl (145.131.10.21)	fb75d4f81be51074bb 4147e781e5b402 (MD5)	66/72
wp.exe	Banking/password-stealing Trojan	vantagepointtechnologies.com (143.95.151.192)	4da48f6423d5f7d75d e281a674c2e620 (MD5)	62/72
t64.bin	Possible configuration or additional module (binary)	rts21.co.jp (59.106.164.230)	69e5e0a17f197cae37 23adfc5f894d49 (MD5)	0/62

Table 4. Malicious files downloaded to the target system during the attack

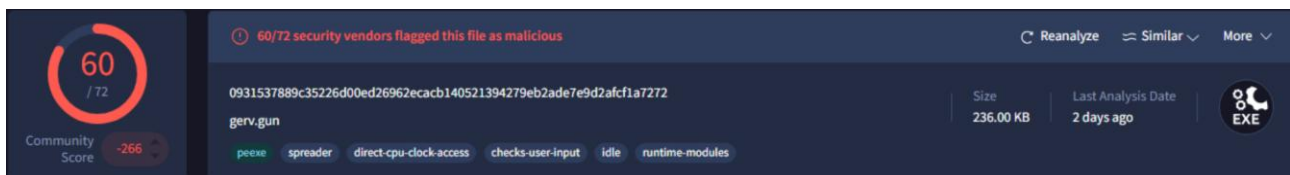


Figure 10. gerv.gun file in VirusTotal

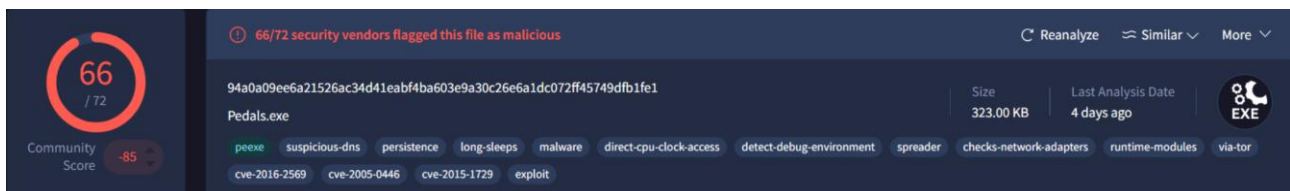


Figure 11. trow.exe file in VirusTotal

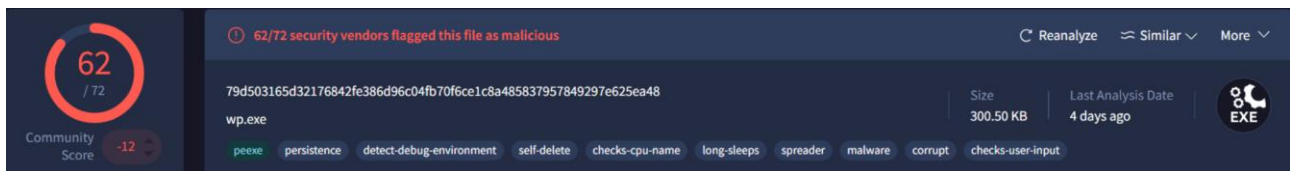


Figure 12. wp.exe in VirusTotal

The files mentioned above were confirmed as malicious in VirusTotal with high detection rates. For example, gerv.gun was detected by 60/72 antivirus engines. According to VirusTotal analyses, each .exe file was a Windows PE32 executable in the 236 KB-323 KB size range. They also had several aliases, which is typical of packed malware that changes its hash value.

6. Summary

Overall, the technical analysis and evidence presented above show that a clear cyber threat incident occurred on the company's network between June 26 and June 28, 2022. The malware chain was reconstructed in chronological order, and its scope remained limited to infection of a single workstation. The attached screenshots and tables support the findings. Recommended immediate follow-up actions are presented at the beginning of the analysis, with the most important being the isolation and forensic examination of the target machine, as well as preventive measures against similar attacks in the future.